Họ và tên: Nguyễn Thị Lan Anh
Mã sinh viên: 23001826
Mã biến thể: RE-005 (tên file: BT1_23001826_RE-005.pdf)
Team ID: SE2026-T02 · Mã đề tài: APP-08 – Resilient Order Workflow
Cam kết: "Tôi chịu trách nhiệm về toàn bộ nội dung bài làm và đã khai báo việc sử dụng AI."

1. Software Engineering trong kỷ nguyên AI

1.1 Ba lý do MVP do AI sinh ra chạy được nhưng chưa đủ tin cậy để bàn giao

Lý do 1: Mới được chạy thử đường thuận, chưa kiểm soát truy cập. MVP chạy đúng khi 1 người dùng thao tác tuần tự, nên lỗi IDOR (người dùng A đọc được đơn của B bằng cách đổi mã đơn) không làm demo hỏng và không bị phát hiện. Bằng chứng cần có: 100% endpoint có kiểm tra quyền; đơn không tồn tại và đơn của người khác cho phản hồi giống hệt nhau, không bao giờ trả dữ liệu đơn.

Lý do 2: Chưa chịu được mạng không ổn định và 148 người dùng đồng thời. Mạng rớt khiến client gửi lại yêu cầu; nếu API đặt đơn không idempotent (gửi lặp vẫn chỉ tạo 1 đơn), 1 lần bấm có thể tạo 2 đơn. Bằng chứng cần có: 0 đơn trùng trong 1.000 lần gửi lặp; p95 ≤ 2 giây ở 148 người dùng đồng thời.

Lý do 3: Không truy vết và bảo trì được. Code không có test tự động, không có nhật ký quyết định thiết kế, và có thể chứa thư viện lỗ hổng hoặc khóa API trong repo, nên khó sửa trong 12 giờ khi có change request. Bằng chứng cần có: độ phủ test ≥ 70% cho module đặt đơn và phân quyền; 0 lỗ hổng Critical/High; 0 secret trong lịch sử commit.

1.2 Trách nhiệm của kỹ sư khi AI viết requirement mơ hồ ("nhanh", "an toàn")

Hai từ này không viết được test nghiệm thu, nên không quyết định được việc hoàn thành hay chưa. Kỹ sư chịu trách nhiệm cuối cùng về requirement, gồm 4 việc:

1. **Đo hóa trước khi giao cho coding agent.**
   - "Nhanh" → p95 đặt đơn ≤ 2 giây ở 148 người dùng đồng thời; trạng thái "đang xử lý" hiện trong ≤ 2 giây.
   - "An toàn" → mỗi endpoint kiểm tra quyền theo 3 vai trò (khách, nhân viên, quản trị); truy cập trái phép cho phản hồi giống hệt đơn không tồn tại; 5 lần đăng nhập sai khóa 15 phút; phiên hết hạn sau 30 phút không hoạt động; TLS 1.2 trở lên.
2. **Ghi nguồn và xác nhận.** Gắn mỗi requirement nhãn "AI đề xuất" hoặc "stakeholder nêu"; xác nhận lại với người dùng mạng không ổn định khi đổi ngưỡng.
3. **Viết tiêu chí nghiệm thu trước khi sinh code.** Mỗi requirement có ≥ 1 test tự động. Với ngân sách kiểm thử hạn chế, ưu tiên 2 rủi ro cao nhất: truy cập chéo và đơn trùng.
4. **Truy vết và kiểm tra ngược.** Mỗi requirement gắn 1 test và 1 commit để xác định phạm vi ảnh hưởng của change request trong 12 giờ. Requirement thiếu đơn vị đo, ngưỡng số, điều kiện tải hoặc cách kiểm chứng thì trả lại cho AI viết lại.

2. Software Process

Quy trình chọn: AI-native + Kanban + iterative/incremental.

- **Incremental:** 3 increment theo rủi ro (phân quyền → đặt đơn idempotent → chịu tải 148 người dùng đồng thời), mỗi increment có bản build kiểm chứng được.
- **Kanban:** WIP limit = 3 thẻ cho cả nhóm; làn riêng "Change request" xử lý trong 12 giờ. Không chọn Scrum vì sprint cố định 1 tuần không cho chèn change request; Kanban chèn được mà không phá kế hoạch 6 checkpoint.

AI-native: coding agent sinh code, nhưng mọi đầu ra phải qua cổng kiểm tra (test tự động + review của kỹ sư) trước khi sang cột tiếp theo.

Workflow 1 tuần:

Checkpoint	Ngày	Hoạt động	Tiêu chí qua
CP1: Yêu cầu đã chốt	1	Viết/duyệt requirement, thay	100% requirement có số đo; 1 requirement

Checkpoint	Ngày	Hoạt động	Tiêu chí qua
		mọi từ mơ hồ bằng số đo	↔ ≥ 1 test nghiệm thu; stakeholder (người dùng mạng yếu) xác nhận trong ≤ 12 giờ
CP2: Thiết kế & mô hình mối đe dọa	2	Sơ đồ vai trò (khách, nhân viên, quản trị), ma trận phân quyền, thiết kế idempotency key	Ma trận phân quyền phủ 100% endpoint; liệt kê ≥ 5 mối đe dọa (IDOR, brute force, replay, lộ secret, leo thang quyền)
CP3: Increment 1 - Phân quyền	3–4	Coding agent sinh code xác thực và phân quyền; kỹ sư review	100% endpoint có kiểm tra quyền; truy cập đơn người khác trả về phản hồi giống hệt nhau cho đơn không tồn tại và đơn của người khác; 5 lần đăng nhập sai khóa 15 phút; 0 secret trong commit
CP4: Increment 2 - Đặt hàng chịu mạng yếu	4–5	Idempotency, timeout, retry giới hạn, lưu hàng đợi phía client	0 đơn trùng trong 1.000 lần gửi lặp; đơn không mất khi mất mạng 30 giây rồi nối lại
CP5: Kiểm thử tải & bảo mật	6	Tải 148 người dùng đồng thời; quét phụ thuộc và quét tĩnh	p95 ≤ 2 giây; tỷ lệ lỗi < 1%; 0 lỗ hổng Critical/High; độ phủ ≥ 70% module đặt hàng và phân quyền
CP6: Bản build kiểm chứng được	7	Đóng băng build, gắn tag, chạy lại toàn bộ test, viết báo cáo truy vết	100% test của CP1–CP5 đạt trên đúng 1 build có tag; dữ liệu tự xóa sau 26 ngày được kiểm chứng bằng test với đồng hồ giả lập

Lý do phù hợp với các ràng buộc

1. **Ngân sách kiểm thử hạn chế:** test dồn vào 2 rủi ro cao nhất (truy cập chéo, đơn trùng) ở CP3–CP4. Tải chạy 1 lần ở CP5. Các CP khác chạy test tự động < 5 phút mỗi lần. Giả định ngân sách của bài: ≤ 8 giờ công kiểm thử trong tuần.
2. **Dùng coding agent:** mỗi đầu ra của agent qua cổng đo được (test tự động + review của kỹ sư) trước khi sang cột tiếp theo, nên lỗi bị chặn trong ≤ 1 ngày.
3. **Tăng 20 lần người dùng:** tải 148 người dùng đồng thời chạy ở ngày 6. Lỗi tải được sửa trong ≤ 4 giờ đầu ngày 7, phần còn lại của ngày 7 dành cho đóng băng và chạy lại toàn bộ test (CP6).
4. **Change request 12 giờ:** làn Kanban riêng với 3 mốc: phân loại ≤ 2 giờ, đánh giá ảnh hưởng bằng bảng truy vết ≤ 4 giờ, phản hồi (xác nhận và ước lượng) ≤ 12 giờ kể từ lúc nhận.
5. **Security là trọng tâm:** phân quyền làm ở ngày 3, trước các tính năng khác, nên mọi increment sau được xây trên nền đã kiểm soát truy cập.
6. **Feedback:** sau CP3 và CP4, 3 người dùng mạng yếu thử bản build. Số lần đặt lặp được ghi lại và đưa vào CP5.

Trade-off

Phản hồi change request ≤ 12 giờ đổi lấy sự ổn định của kế hoạch. Mỗi change request chen ngang nâng WIP từ 3 lên 4 thẻ, giả định tốn 2–4 giờ công. Nếu có hơn 2 change request trong tuần, CP5 bị rút ngắn, làm giảm độ tin cậy về hiệu năng. Giảm thiểu: tối đa 2 change request chen ngang; từ cái thứ 3 chuyển sang backlog tuần sau.

3. Product Thinking

3.1 Problem statement

Người đặt đơn khi kết nối chập chờn không biết đơn của mình đã được ghi nhận hay chưa, nên phải đoán và đặt lại, dẫn đến đơn trùng hoặc đơn mất. Trong tuần demo, số người dùng đồng thời tăng từ 7

(làm tròn từ 148/20 = 7,4) lên 148, nên số lượt gặp tình huống này tăng theo. Đơn chứa họ tên và địa chỉ, nên chủ đơn cần chắc rằng chỉ mình và nhân sự của cửa hàng nhận đơn xem được. Người dùng cần đơn của mình được ghi nhận đúng một lần và thông tin của mình không lộ cho người khác, ngay cả khi mạng gián đoạn.

	User outcome	Product outcome
Phát biểu	Người dùng mạng yếu biết chắc đơn của mình đã được ghi nhận hay chưa trong ≤ 5 giây sau lần bấm cuối, và không phải đặt lại.	Giảm đơn trùng và đơn thất lạc, đồng thời không có truy cập trái phép vào đơn hàng trong tuần demo.
Số đo	≥ 95% lượt đặt đơn trên mạng mất kết nối 30 giây cho ra trạng thái rõ ràng (đã ghi nhận / chưa ghi nhận) trong ≤ 5 giây sau khi nối lại; 0 đơn trùng do bấm lặp.	Tỷ lệ đơn trùng/thất lạc < 0,5% tổng số đơn; 0 sự cố truy cập trái phép trong 7 ngày demo; ≤ 2 yêu cầu hỗ trợ "đơn của tôi đâu" trên 100 đơn
Khác nhau	Đo trải nghiệm của từng người dùng.	Đo kết quả vận hành và rủi ro của tổ chức.

3.3 Hai giả định nguy hiểm và cách kiểm chứng rẻ nhất

Giả định 1: Người dùng mạng yếu sẵn sàng chờ trạng thái "đang xử lý" thay vì bấm lại.

- **Lý do nguy hiểm:** nếu sai, người dùng vẫn bấm lặp và thiết kế chống trùng đơn không giải quyết được hành vi thật, đồng thời làm tăng tải do gửi lặp.
- **Cách kiểm chứng rẻ nhất:** thử nghiệm giả lập với 5 người thật trên điện thoại, dùng chế độ giới hạn băng thông của trình duyệt (miễn phí), làm chậm 3 giây rồi 10 giây. Đếm số lần bấm lặp. Ngưỡng: nếu ≥ 2/5 người bấm lặp trước 5 giây thì giả định sai. Chi phí: khoảng 1 giờ, 0 đồng.

Giả định 2: Việc phân quyền theo vai trò (khách, nhân viên, quản trị) đủ để ngăn truy cập trái phép vào đơn hàng.

- **Lý do nguy hiểm:** vai trò không ngăn người dùng cùng vai trò xem đơn của nhau (IDOR). Nếu giả định sai, dữ liệu cá nhân lộ ra mà không có dấu hiệu lỗi nào ở giao diện.
- **Cách kiểm chứng rẻ nhất:** viết 1 test tự động tạo 2 tài khoản cùng vai trò "khách", tài khoản A đặt 1 đơn, tài khoản B truy cập đơn đó. Kết quả mong đợi: HTTP 403. Chạy trên 100% endpoint có mã đơn. Chi phí: khoảng 2 giờ, chạy < 1 phút mỗi lần, không cần công cụ trả phí.

Bên liên quan	Vai trò	Mối quan tâm chính	Mức ảnh hưởng	Mức quan tâm
Người dùng mạng không ổn định (trọng tâm)	Người đặt đơn	Đơn không trùng, không mất; biết trạng thái rõ ràng	Thấp (từng người)	Cao
Người bán / nhân viên xử lý đơn	Nhận và xử lý đơn	Đơn đúng, đủ; ít hỗ trợ "đơn của tôi đâu"	Trung bình	Cao
Quản trị hệ thống / chủ sản phẩm	Chịu trách nhiệm demo và dữ liệu	Không sự cố bảo mật; 148 người dùng đồng thời chạy ổn	Cao	Cao
Nhóm phát triển (kỹ sư + coding agent)	Xây dựng và sửa	Giao đúng hạn; phản hồi change request trong 12 giờ	Cao	Cao

3.5 Xung đột cần giải quyết

Xung đột:

Người dùng mạng yếu (cần dễ truy cập, ít bị đăng xuất) ↔ Quản trị hệ thống (cần phiên ngắn, kiểm soát chặt).

- **Biểu hiện:** nếu phiên hết hạn sau 30 phút không hoạt động và mỗi lần mất mạng buộc đăng nhập lại, người dùng mạng yếu có thể mất giỏ hàng hoặc đơn đang đặt dở. Nếu kéo dài phiên lên 24 giờ để thuận tiện, rủi ro chiếm quyền phiên tăng.
- **Cách giải quyết :**
    - Phiên hết hạn sau 30 phút không hoạt động, nhưng **không tính thời gian mất kết nối** là không hoạt động: bộ đếm tạm dừng tối đa 5 phút khi mất mạng.
    - Đơn đang đặt dở được giữ ở thiết bị tối đa 15 phút và chỉ gửi được sau khi xác thực lại thành công, nên không mất dữ liệu nhưng cũng không bỏ qua kiểm soát truy cập.
    - Đăng nhập lại chỉ yêu cầu 1 bước (không thêm xác minh phụ) nếu thiết bị đã được nhận diện trong 26 ngày gần nhất, cùng thời hạn lưu dữ liệu.
- **Tiêu chí kiểm tra:** 0 đơn bị mất khi mất mạng ≤ 5 phút và phiên còn hiệu lực; 0 đơn gửi được bằng phiên đã hết hạn.
- **Phần đánh đổi:** chấp nhận cửa sổ rủi ro 5 phút để giữ trải nghiệm cho người dùng mạng yếu; nếu phát hiện lạm dụng, quản trị có thể hạ xuống 0 phút bằng 1 thay đổi cấu hình, xử lý trong khung 12 giờ của change request.

4. Requirements Engineering

4.1 Bốn user stories

US1 – Đặt đơn khi mạng chập chờn. Là khách có mạng không ổn định, tôi muốn biết chắc đơn đã được ghi nhận hay chưa, để không phải đặt lại..

Mã – loại	Given	When	Then
AC1.1 – Thành công	Khách đã đăng nhập, giỏ có 3 dòng hàng, mạng ổn định	Bấm "Xác nhận đặt" 1 lần	Trong ≤ 2 giây (p95) hiện mã đơn và trạng thái "Đã ghi nhận"; có đúng 1 đơn
AC1.2 – Lỗi (mất mạng)	Mạng mất ngay sau khi bấm "Xác nhận đặt"	Bấm thêm 3 lần trong 30 giây mất mạng, rồi mạng nối lại	Trong ≤ 5 giây sau khi nối lại, hiện "Đã ghi nhận" hoặc "Chưa ghi nhận"; số đơn tạo ra là 0 hoặc 1, không bao giờ ≥ 2
AC1.3 – Lỗi (2 thiết bị)	Hai thiết bị cùng tài khoản, cùng danh sách hàng và số lượng	Cả hai bấm "Xác nhận đặt" trong cùng 1 giây	Có đúng 1 đơn; thiết bị còn lại hiện "Đơn đã tồn tại" kèm mã đơn đó
AC1.4 – Biên	Giỏ có đúng 20 dòng hàng	Bấm xác nhận; sau đó thử thêm dòng thứ 21	Đơn 20 dòng được ghi nhận; dòng thứ 21 bị từ chối với "Tối đa 20 dòng hàng mỗi đơn", giỏ giữ nguyên 20 dòng

US2 – Xem đơn của chính mình. Là khách, tôi muốn xem đơn của mình trong 26 ngày mà người khác không xem được.

Mã – loại	Given	When	Then
AC2.1 – Thành công	Khách A có 3 đơn trong 26 ngày gần nhất	A mở danh sách đơn	Hiện đúng 3 đơn của A, 0 đơn của tài khoản khác
AC2.2 – Lỗi (xem đơn	Khách B có mã đơn của A; B cũng thử một	B nhập từng mã để xem	Cả hai lần đều hiện "Không tìm thấy đơn", cùng nội dung và cùng mã trạng

Mã – loại	Given	When	Then
người khác)	mã không tồn tại		thái; 0 trường dữ liệu của đơn A xuất hiện; có 1 dòng nhật ký cho mỗi lần bị từ chối
AC2.3 – Biên (26 ngày)	Đơn X tạo cách đây 25 ngày 23 giờ 59 phút; đơn Y cách đây 26 ngày 0 giờ 1 phút	Khách mở danh sách và tra cứu trực tiếp	X còn xem được; Y không hiển thị, tra cứu trực tiếp hiện "Đơn đã quá thời hạn lưu 26 ngày"

US3 – Nhận và xử lý đơn. Là nhân viên, tôi muốn nhận đơn của cửa hàng mình và cập nhật trạng thái, để khách biết tiến độ.

Mã – loại	Given	When	Then
AC3.1 – Thành công	Nhân viên cửa hàng 1 đã đăng nhập; có 5 đơn "Đã ghi nhận" của cửa hàng 1	Đổi 1 đơn sang "Đang chuẩn bị"	Khách thấy trạng thái mới trong ≤ 5 giây; nhân viên chỉ thấy 5 đơn của cửa hàng 1
AC3.2 – Lỗi	Có 1 đơn của cửa hàng 2; có 1 đơn "Đã giao"	Nhân viên cửa hàng 1 mở đơn của cửa hàng 2 và thử hủy đơn "Đã giao"	Cả 2 thao tác bị từ chối kèm lý do; trạng thái đơn không đổi; có 2 dòng nhật ký từ chối
AC3.3 – Biên (nhận đơn đồng thời)	2 nhân viên cùng cửa hàng, 1 đơn "Đã ghi nhận"	Cả hai bấm "Nhận đơn" trong cùng 1 giây	Đúng 1 người nhận thành công; người còn lại thấy "Đơn đã được nhận"; đơn có đúng 1 người phụ trách

US4 – Đăng nhập và giữ phiên an toàn (khách). Là khách, tôi muốn đăng nhập lại nhanh sau khi mất mạng và tài khoản không bị dò mật khẩu.

Mã – loại	Given	When	Then
AC4.1 – Thành công	Khách có tài khoản hợp lệ	Nhập đúng mật khẩu	Vào được trong ≤ 2 giây (p95)
AC4.2 – Lỗi (khóa tài khoản)	Đã nhập sai 5 lần liên tiếp	Nhập lần thứ 6, kể cả đúng mật khẩu	Bị từ chối, hiện "Tài khoản bị khóa 15 phút"; đến phút 15 đăng nhập lại được
AC4.3 – Biên (số lần sai)	Đã nhập sai 4 lần	Nhập sai lần thứ 5	Hiện "Sai mật khẩu, tài khoản sẽ bị khóa" và khóa đúng ở lần sai thứ 5, không khóa sớm hơn
AC4.4 – Biên (hết phiên)	Khách có đơn nháp; phiên không hoạt động 29 phút, rồi thêm 2 phút nữa (tổng 31 phút)	Gửi thao tác ở phút 29, rồi ở phút 31	Phút 29: thao tác thành công. Phút 31: yêu cầu đăng nhập lại, không gửi được bằng phiên cũ; đơn nháp vẫn giữ trong 15 phút

4.2 Quality attribute scenario: Security

Thành phần	Nội dung
Source	20 tài khoản khách đã xác thực, có hành vi dò quyền
Stimulus	Mỗi tài khoản gửi 10 yêu cầu trái phép trong 60 giây: 8 yêu cầu xem, sửa hoặc hủy đơn của tài khoản khác, 2 yêu cầu gọi chức năng nhân viên hoặc quản trị. Tổng 200 yêu cầu
Artifact	Chức năng xem, sửa, hủy đơn; chức năng nhân viên; chức năng quản trị
Environment	Vận hành bình thường, 148 người dùng đồng thời, mạng mất kết nối ngẫu nhiên 30 giây
Response	Từ chối từng yêu cầu không đủ quyền, không trả dữ liệu đơn, ghi nhật ký, thu hồi phiên khi vượt ngưỡng, cảnh báo quản trị
Response measure	(1) 200/200 yêu cầu trái phép bị từ chối. (2) 0 byte dữ liệu đơn của tài khoản khác bị trả về. (3) 100% yêu cầu bị từ chối có 1 dòng nhật ký (thời gian, tài khoản, đối tượng) trong ≤ 5 giây. (4) Phiên của 20/20 tài khoản bị thu hồi ngay sau lần từ chối thứ 10. (5) Cảnh báo tới quản trị trong ≤ 60 giây. (6) p95 phản hồi của người dùng hợp lệ ≤ 2 giây trong lúc đó

4.3 MoSCoW cho MVP

Nhóm	Mục	Căn cứ
Must	Đặt đơn không trùng, không mất (US1)	Nhu cầu cốt lõi của stakeholder trọng tâm
	Xem đơn của chính mình, kiểm tra chủ sở hữu (US2)	Security: 0 byte lộ dữ liệu
	Nhận và đổi trạng thái đơn theo cửa hàng (US3)	Hoàn thành luồng đơn hàng
	Đăng nhập, khóa 15 phút sau 5 lần sai, phiên 30 phút (US4)	Security
	Giữ đơn nháp 15 phút khi mất mạng AC4.4	Người dùng mạng yếu không mất dữ liệu
	Phân quyền 3 vai trò trên 100% chức năng; nhật ký từ chối	Security; đo (1), (3) của QAS
	Mã hóa khi truyền (TLS 1.2 trở lên)	Security
	Tự xóa dữ liệu sau 26 ngày	Tham số đề bài
	p95 đặt đơn ≤ 2 giây ở 148 người dùng đồng thời, tỷ lệ lỗi < 1%	Biến cố tăng 20 lần

Nhóm	Mục	Căn cứ
Should	Thu hồi phiên sau 10 lần bị từ chối; cảnh báo quản trị ≤ 60 giây	Đo (4), (5) của QAS; hạ xuống thủ công nếu hết thời gian
Could	Tìm kiếm, lọc đơn theo ngày; xuất CSV	Không ảnh hưởng Security hay độ tin cậy
Won't (vòng đầu)	Thanh toán trực tuyến	Thêm bề mặt tấn công, vượt ngân sách kiểm thử
	Xác thực 2 bước	Thay bằng khóa 15 phút; thêm ≥ 6 kịch bản test
	Đăng nhập bằng mạng xã hội	Phụ thuộc bên thứ ba, khó kiểm thử
	Ứng dụng di động riêng	Bản web đáp ứng yêu cầu demo

5. Engineering Evidence và AI Reflection

5.1 Hai trích đoạn phỏng vấn giả định

#	Trích đoạn (giả định)	Người nói và bối cảnh	Giả định kiểm chứng	Cách xác minh và ngưỡng
1	"Mình thấy xoay mãi nên bấm gửi thêm 2-3 lần."	Người đặt đơn, mạng mất 10-30 giây	Người dùng bấm lặp trước 5 giây (Giả định 1 - AC1.2)	6 người thử trên bản mô phỏng giấy, trễ 3 giây rồi 10 giây. **≥ 4/6** bấm lặp trước 5 giây thì giả định đúng.
2	"Mình hay gửi mã đơn cho người nhà để họ xem hộ."	Người đặt đơn, đặt thay cho gia đình	Chủ đơn cần chia sẻ đơn, mâu thuẫn với quyền chỉ chủ đơn xem (Giả định 2 - A2.2)	Hỏi 6 người. **≥ 2/6** cần chia sẻ thì đưa vào backlog, không đổi MVP vòng đầu.

5.2 Prompt và output AI

- **Prompt :** "APP-08 RE-005, 148 người dùng đồng thời, dữ liệu 26 ngày, 12 giờ phản hồi change request, Security. Viết 4 user story có Given/When/Then gồm failure case và boundary case, không nêu cách cài đặt; viết quality attribute scenario cho Security."
- **Trích output AI:** "Khách B nhập mã đơn của khách A → bị từ chối với 'Không có quyền xem đơn này'; 0 trường dữ liệu của đơn A xuất hiện."

Chỗ sửa hoặc bác bỏ:

#	Hành động	Nội dung	Lý do
1	**Sửa**	Thông báo "Không có quyền xem đơn này" → "Không tìm thấy đơn", giống hệt phản hồi khi mã không tồn tại (AC2.2); bỏ yêu cầu "HTTP 403"	Thông báo cũ cho biết đơn tồn tại, mâu thuẫn với yêu cầu không lộ dữ liệu.
2	**Sửa**	Stimulus của QAS: 1 tài khoản gửi 120 yêu cầu → 20 tài khoản × 10 yêu cầu (200/200)	Quy tắc thu hồi phiên sau 10 lần bị từ chối sẽ cắt phiên ngay từ yêu cầu thứ 11, nên 120/120 không kiểm thử

			được.
3	**Sửa**	Trạng thái "đang xử lý" ≤ 300 ms → ≤ 2 giây	Lệch với AC1.1 (≤ 2 giây); một hành vi có hai ngưỡng thì không có test nào kiểm được cả hai.
4	**Bác bỏ**	AI đề xuất "2 lần trừ tiền" làm hậu quả của đơn trùng	Thanh toán nằm ở Won't vòng đầu; hậu quả đổi thành "2 đơn cho 1 lần bấm".

5.3 Bảng truy vết

Outcome	Requirement	Acceptance criterion	Planned test (ngưỡng đạt)
O1 (user): biết chắc đơn đã ghi nhận hay chưa trong ≤ 5 giây sau khi nối lại	R1: trạng thái rõ ràng ≤ 5 giây sau nối lại	AC1.1–AC1.4 (đồng bộ AC1.2 về ≤ 5 giây)	T1: mất mạng 5–30 giây × 50 lần; đạt khi ≥ 48/50 lần (≥ 95%)
	R2: không đơn trùng	AC2.1, AC2.2	T2: gửi lặp 3 lần × 100 ca (gồm 20 ca hai thiết bị); đạt khi 0 đơn trùng
O2 (product): 0 truy cập trái phép trong test; < 0,5% đơn trùng hoặc thất lạc	R3: từ chối truy cập chéo, không lộ đơn tồn tại	AC4.1, AC4.2; QAS (1)(2)(4)	T3: ≥ 200 ca truy cập chéo; đạt khi 200/200 bị từ chối, log ≤ 5 giây, p95 từ chối ≤ 1 giây
	R4: phiên hết hạn không gửi được đơn	AC4.3; QAS (3)	T4: 50 ca gửi lại bằng phiên hết hạn; đạt khi 50/50 bị từ chối
	R5: khóa 15 phút sau 5 lần sai	US4 (cần thêm AC)	T5: 6 lần sai liên tiếp; đạt khi lần 6 bị khóa, tại phút 15 đăng nhập lại được
	R6: dữ liệu quá 26 ngày không truy cập được, xóa ≤ 24 giờ	AC3.3; QAS (5)	T6: đồng hồ giả lập tại 25 ngày 23 giờ và 26 ngày 1 giờ; đạt khi đúng quy tắc hiển thị và xóa
	R7: p95 đặt đơn ≤ 2 giây ở 148 đồng thời, lỗi < 1%	AC1.1	T7: 1 lần chạy tải 148 đồng thời, ≤ 5 phút
	R8: phản hồi change request ≤ 12 giờ (xác nhận và ước lượng)	Quy trình ở Mục 2	T8: diễn tập 2 change request; đạt khi cả 2 có phản hồi ≤ 12 giờ

Phụ lục – AI Usage Log

#	Công cụ	Prompt chính	AI đề xuất	Giữ / Sửa / Bác bỏ
1	Claude	"Nêu 3 lý do MVP do AI sinh ra chưa đủ tin cậy để bàn giao; trách nhiệm kỹ sư khi AI viết 'nhanh', 'an toàn'"	3 lý do (thiếu phân quyền, không chịu mạng yếu, khó truy vết), kèm ngưỡng: độ phủ test ≥ 70%, 0 lỗ hổng Critical/High, p95 ≤ 2 giây	**Giữ**
2	Claude	Như trên	Trạng thái "đang xử lý" hiển thị trong ≤ 300 ms (Mục 1)	**Sửa** → ≤ 2 giây
3	Claude	Như trên	"2 lần trừ tiền" làm ví dụ hậu quả của đơn trùng (Mục 1, lý do 2)	**Bác bỏ**
4	Claude	"Chọn quy trình, thiết kế workflow 1 tuần ≥ 5 checkpoint, nêu trade-off"	AI-native + Kanban + incremental; 6 checkpoint; WIP = 3	**Giữ** quy trình; **Sửa** lịch
5	Claude	"Viết 4 user story có Given/When/Then, có failure và boundary case; QAS cho Security; MoSCoW"	Phản hồi từ chối truy cập đơn người khác là HTTP 403 (Mục 1, CP3, 3.3)	**Sửa** → phản hồi giống hệt nhau cho đơn không tồn tại và đơn của người khác
6	Claude	"Viết quality attribute scenario cho Security"	QAS đủ 6 thành phần, 6 số đo, kịch bản test ≤ 5 phút	**Giữ**, **Sửa** số ca